

Question 1

Question 1.1

Policy A:

"Mandatory Multi-Factor Authentication (MFA) for all cloud applications and VPN access"

Policy Description: This policy sets mandatory security rules to confirm the identity of an employee. This can be achieved through different methods such as fingerprints, pins or answers to security questions.

Pros/Advantages

- In the event of a successfully phishing attempt, attackers are still unable to gain access to MFA.
- It reduces the chances of identity fraud.
- It will prevent unauthorized access.

Cons/Disadvantages

- Can be time consuming and frustrating to always use MFA for each login
- Possible lockouts if the verification phone is lost or person is not in possession of their key cards
- Sim based MFA is more susceptible to interception.

Estimated cost – Medium

Reason: Depending on the method which the company best finds it, the cost could medium or low. Low if the MFA is done with their number and not requiring a separate work smartphone.

Implementation complexity – Low

Reason: it is not difficult to roll this out and get employees accustomed to using MFA for every login. Although it could be time consuming to create the software.

Policy D:

"Data classification and handling policy - all sensitive data must be encrypted at rest and in transit"

Policy Description: This policy ensures that all data is categorised based on its sensitivity, this ensure that the highest level of protection is given to sensitive data such PII (Personal Identifiable Information) and PHI (Protected Health information). This can be achieved by restricting access (applying permissions) through the use of an ACL (Access Control List) to limit unauthorized access.

Pros/Advantages

- This will ensure that if a phishing attempt is successful, the attacker will not have access to sensitive data
- Encryption of data at rest and in transit will ensure that data is encoded and that only certain people can read it. This can be achieve through Transport Layer Security and Database encryption
- Restrictions to confidential data, requiring approval

Cons/Disadvantages

- There is little to no protection of data in transit as there many different switches, router and devices.
- It can be complex to implement

- May not solve the problem as there could be other malicious actors such as Shadow IT.

Estimated cost – Low

Low cost as it all about the IT department applying permissions to the already existing systems and software's

Implementation Complexity – Low

Less complex to apply permissions and categorize sensitive data and encrypt it as well as the TLS.

Question 1.2

Policy D seems rather more fitting as the attacker managed to access 50 employee salary records and gained access to a shared HR folder. As policy D deals with data protection and encryption at rest and in transit, policy D would have prevented access to personal identifiable information as this data would have been encrypted.

Using policy D is less costly for SafariPay as it has a low estimated cost and a low implementation complexity. As per the PCI-DSS, policy D covers the requirement for a strong encrypting of data at rest and in transit.